Vulnerability Management Policy

Organization: COOKIE-BANNER.CA **Contact:** security@cookie-banner.ca **Effective Date:** 2026-03-28 **Last Reviewed:** 2026-03-28 **Next Review:** 2026-09-28 **Owner:** Founder / Security Lead

---

1. Purpose

This policy defines how COOKIE-BANNER.CA identifies, evaluates, remediates, and tracks security vulnerabilities across its cookie consent management platform. It ensures a consistent, risk-based approach to vulnerability management appropriate for a small, fully remote SaaS operation.

2. Scope

This policy applies to all systems, code, dependencies, and infrastructure that support the COOKIE-BANNER.CA platform, including:

- Application source code (Next.js, React, TypeScript)
- Third-party dependencies (npm packages)
- Infrastructure services (Vercel, Supabase, Stripe, GitHub)
- Authentication systems (NextAuth.js)
- Database layer (Supabase PostgreSQL)

3. Vulnerability Detection Sources

Vulnerabilities are identified through the following channels, monitored on an ongoing basis:

Source	Type	Frequency
GitHub Dependabot	Dependency vulnerabilities	Continuous (automated)
GitHub Security Advisories	Supply chain and code vulnerabilities	Continuous (automated)
`npm audit`	Dependency vulnerabilities	Every build + weekly manual review
Supabase Security Advisories	Database and platform advisories	As published
Vercel Security Notifications	Hosting and edge platform advisories	As published
CVE Databases (NVD, MITRE)	Industry-wide vulnerability disclosures	Weekly review
OWASP Top 10	Application security baseline	Each development cycle

4. Severity Classification and Remediation SLAs

Vulnerabilities are classified using CVSS v3.1 scores aligned with the following severity levels:

Severity	CVSS Score	Remediation SLA	Examples
Critical	9.0 – 10.0	**24 hours**	Remote code execution, authentication bypass, data breach exposure
High	7.0 – 8.9	**7 days**	SQL injection, XSS with data exfiltration, privilege escalation
Medium	4.0 – 6.9	**30 days**	CSRF, information disclosure, denial of service

Severity	CVSS Score	Remediation SLA	Examples
Low	0.1 – 3.9	**Next scheduled maintenance**	Minor information leakage, low-impact misconfigurations

SLA timelines begin from the date of detection or public disclosure, whichever is earlier.

5. Dependency Management

- **Automated scanning:** Dependabot is enabled on all repositories and configured to open pull requests for vulnerable dependencies automatically.
- **Regular updates:** Dependencies are reviewed and updated at minimum monthly. Security-critical updates are applied within the SLA for their severity level.
- **Lock files:** `package-lock.json` is committed to source control to ensure reproducible builds and prevent supply chain drift.
- **Audit on build:** `npm audit` runs as part of the CI pipeline; builds producing critical or high vulnerabilities are flagged for immediate review.

6. Infrastructure Vulnerability Management

COOKIE-BANNER.CA operates as a fully cloud-hosted, serverless platform with no physical infrastructure. Infrastructure security is delegated to SOC 2 Type II certified providers:

- **Vercel** – Application hosting, edge network, and SSL/TLS termination
- **Supabase** – PostgreSQL database, authentication services, and storage
- **Stripe** – Payment processing (PCI DSS Level 1 compliant)
- **GitHub** – Source control, CI/CD, and secrets management

Provider security postures are reviewed annually by verifying current SOC 2 reports and compliance certifications. Any provider security advisory affecting COOKIE-BANNER.CA is treated as an internal vulnerability and triaged per the SLAs above.

7. Application Security

The development process incorporates the following application security practices:

- **OWASP Top 10 awareness:** All code is developed with OWASP Top 10 risks in mind, including injection, broken authentication, sensitive data exposure, and security misconfiguration.
- **Input validation:** All user input and API request bodies are validated using Zod schemas before processing.
- **Output encoding:** Server-rendered content is escaped by default through React's built-in XSS protections.
- **Authentication and authorization:** NextAuth.js manages session security. API routes enforce authorization checks before data access.
- **Secrets management:** All secrets are stored in environment variables managed through Vercel and GitHub; no secrets are committed to source control.
- **Secure headers:** HTTP security headers (CSP, HSTS, X-Frame-Options) are configured at the application and platform level.

8. Patch Management Process

1. **Detection** – Vulnerability identified through any source listed in Section 3.
2. **Triage** – Severity assessed using CVSS score; SLA clock starts.
3. **Remediation** – Patch applied, dependency updated, or mitigation implemented.
4. **Testing** – Fix verified in a preview/staging environment before production deployment.
5. **Deployment** – Pushed to production via the standard CI/CD pipeline (GitHub to Vercel).
6. **Verification** – Post-deployment check confirms the vulnerability is resolved.
7. **Documentation** – Vulnerability and remediation recorded in the internal security log.

9. Exception Handling

When a vulnerability cannot be remediated within its SLA, a risk acceptance exception is documented containing:

- Vulnerability description and severity
- Reason remediation cannot be completed on schedule (e.g., no patch available, breaking dependency change)
- Compensating controls in place to reduce risk
- Revised target remediation date
- Acceptance approved by the Founder / Security Lead

Exceptions are reviewed monthly and closed as soon as a viable remediation path becomes available.

10. Roles and Responsibilities

Role	Responsibility
Founder / Security Lead	Policy ownership, vulnerability triage, remediation, exception approval, and compliance oversight
Infrastructure Providers	Maintaining platform-level security, publishing advisories, and providing SOC 2 attestations

As a solo-founder organization, all operational security responsibilities are held by the founder. If the team grows, this section will be updated to reflect delegated responsibilities.

11. Reporting and Metrics

The following metrics are tracked quarterly:

- Total vulnerabilities detected (by severity)
- Mean time to remediation (by severity)
- Number of open exceptions and their age
- Dependency update currency (percentage of dependencies on latest patch version)

A summary is maintained internally and made available upon request for compliance audits (GDPR, PIPEDA, Law 25, PECR).

12. External Vulnerability Reporting

Security researchers and external parties can report vulnerabilities to **security@cookie-banner.ca**. Reports are acknowledged within 48 hours and triaged using the same severity classification and SLA framework defined in this policy.

13. Review Schedule

This policy is reviewed and updated **semi-annually**, or sooner if triggered by:

- A significant security incident
- A material change in technology stack or infrastructure providers
- New regulatory requirements affecting GDPR, PIPEDA, Law 25, or PECR compliance

---